

Ethical Hacking and Penetration Testing Basics

What is penetration or pen testing:

Penetration testing (or pen testing) is a security exercise where a cyber-security expert attempts to find and exploit vulnerabilities in a computer system. The purpose of this simulated attack is to identify any weak spots in a system's defenses which attackers could take advantage of.

5 phases of penetration:

Phase 1: Reconnaissance (Information Gathering)

It collects as much information as possible about the target before touching any systems. It has two types:

Passive Recon	Active Recon
No direct interaction with the target	Direct interaction with the target's systems
Uses OSINT (Open-Source Intelligence). WHOIS lookups, DNS enumeration (dig, nslookup) Search engines (Google dorking), Shodan, Censys Social media, job postings, GitHub repos TheHarvester, Recon-ng, Maltego	DNS zone transfers, subdomain brute-forcing Email enumeration, web crawling Tools: dnsrecon, gobuster, ffuf, sublist3r

Phase 2: Scanning & Enumeration

It Identify live hosts, open ports, running services, and their versions.

Key activities:

- Network Scanning: nmap for port discovery, service detection, OS fingerprinting
- Vulnerability Scanning: Nessus, OpenVAS, Nikto (web), WPScan (WordPress)
- Enumeration: Digging deeper into discovered services
- SMB: smbclient, enum4linux
- HTTP: gobuster, dirb, whatweb
- Databases: nmap scripts, sqlmap
- SNMP: snmpwalk, onesixtyone

Phase 3: Exploitation

It Gain unauthorized access by exploiting identified vulnerabilities.

Common techniques:

- Web: SQL injection, XSS, LFI/RFI, SSRF, command injection
- Network: Outdated service exploits (e.g., vsftpd, Samba), default credentials
- Credential attacks: Hydra, John the Ripper, Hashcat
- Framework: Metasploit (msfconsole) for pre-built exploits
- Manual exploitation: Custom scripts (Python, Bash, PowerShell)

Phase 4: Post-Exploitation:

Maintain access, escalate privileges, pivot, and extract value

Activities:

- Privilege Escalation: Linux (linpeas, GTF0Bins), Windows (winpeas, JuicyPotato)
- Persistence: Backdoors, scheduled tasks, SSH keys, cron jobs
- Lateral Movement: Pivot to other hosts using the compromised machine as a foothold
- Data Exfiltration: Tar and encrypt sensitive data, exfiltrate via DNS/HTTP/ICMP
- Covering Tracks: Clearing logs (though in authorized tests you often preserve them for the report)

Phase 5: Reporting

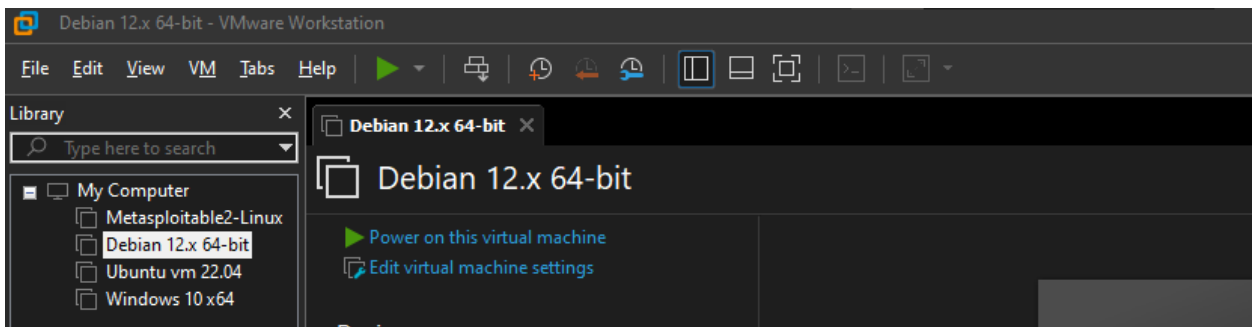
Document everything in a clear, actionable format.

Report structure:

- Executive Summary (non-technical, business impact)
- Scope & Methodology
- Findings (each with: Title, Severity, Description, Proof of Concept, Remediation, CVSS score)
- Risk Ratings (Critical/High/Medium/Low/Informational)
- Remediation Recommendations (short-term and long-term)
- Appendix (raw scans, exploit code, detailed logs)

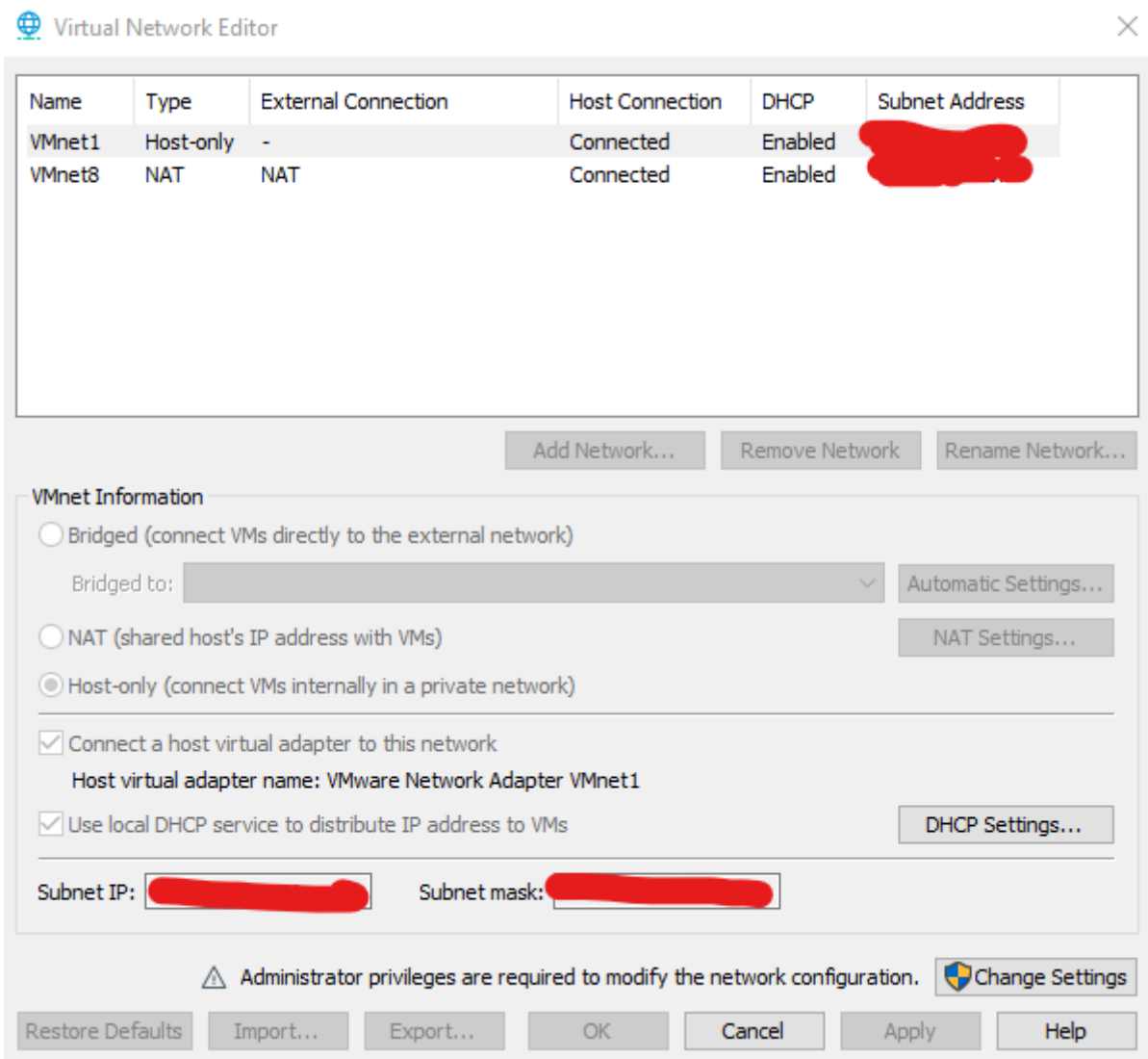
Lab setup

1. Using vmware as I have already installed it



Library contains all your vms that can be accessed easily at any time.

2. Go in edit option in the ribbon above and set the virtual network for your vm preferably, NAT or HOST-only



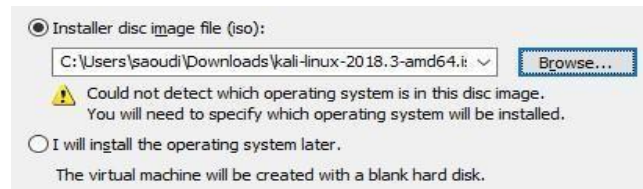
3. Installation of kali iso image by using this link <https://www.kali.org/get-kali/#kali-virtual-machines>

Kali Linux (VirtualBox image) <https://www.kali.org/get-kali/#kali-virtual-machines>

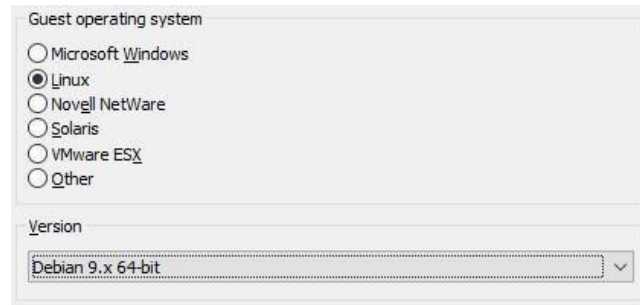
4. Downloading will take much time after downloaded completely create a vm in vmware
5. Open VMware Workstation and create a new virtual Machine (File ☐ New Virtual Machine...)



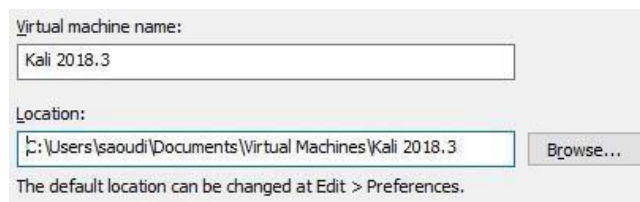
6. Keep **Typical configuration** and click **Next**
7. In the Guest Operating System page, select **Installer disk image file (iso)** and browse to select the newly downloaded **ISO** file, and click Next



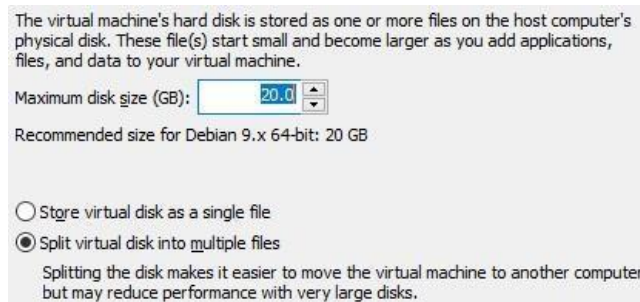
8. For the Operating System, select **Linux** and from the dropdown menu, select **Debian** (any version since Kali is a 'Debian-like' distribution), and click **Next**



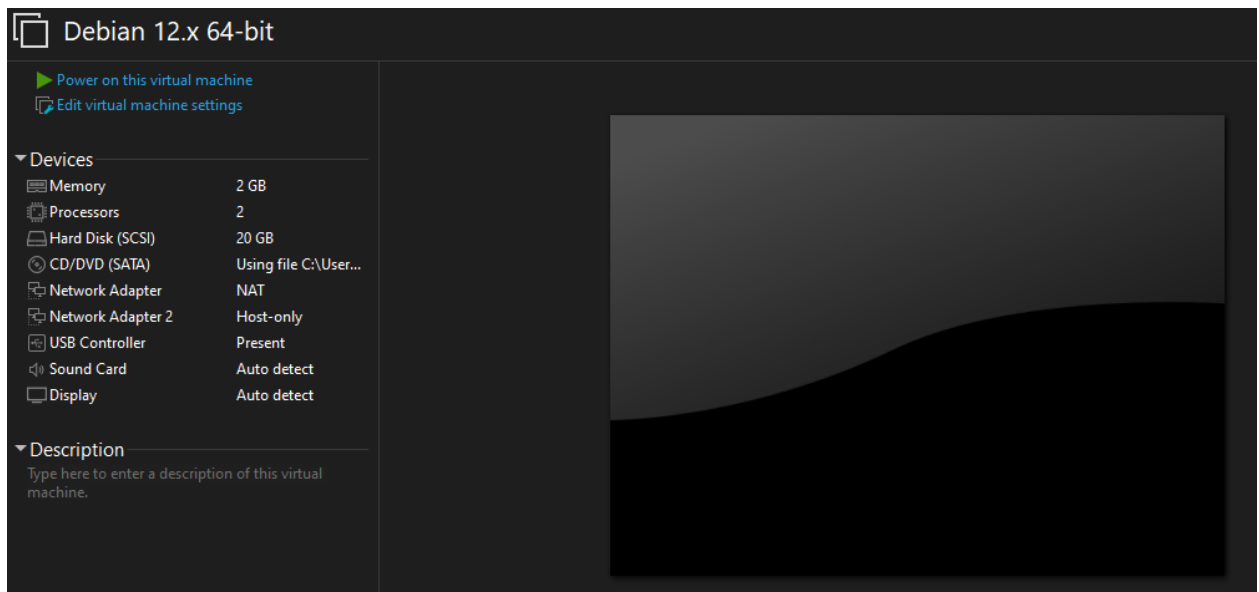
9. Type **Kali 2018.3** as the VM name and note the default location folder (don't change it), then click **Next**



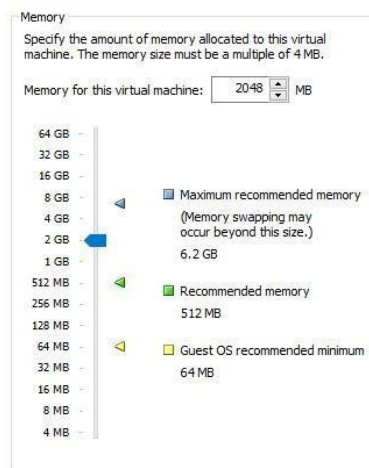
10. The default size of **20GB** should be enough. Keep the defaults and click **Next**



11. Verify the summary info and click **Finish**



12. Click the **Edit virtual machine settings** to change the memory to 2048 MB (2GB) as shown below



13. Click OK to save the changes
14. The VM is created but Kali is not yet installed on the virtual disk. In VMware Workstation, click the **Power on this virtual machine**
15. If you get a warning prompt, click Ok and in the boot menu, select the **Graphical install** option and hit enter
16. Leave the default **language** (English), **country** (Other ☐ Asia ☐ United Arab Emirates), **locale** United States, and **keyboard** (American English)
17. For the **hostname**, type any name and continue



Configure the network

Please enter the hostname for this system.

The hostname is a single word that identifies your system to the network. If you don't know what your hostname should be, consult your network administrator. If you are setting up your own home network, you can make something up here.

Hostname:

18. Leave the domain name empty and **continue**

19. Type **any password** as the root password, re-enter and **continue**

root password:

☒ Show Password in Clear

Please enter the same root password again to verify that you have typed it correctly.

Re-enter password to verify:

☒ Show Password in Clear

20. Accept the default **clock** configuration

21. Accept the default **disk partition** configurations (you need to click **continue** few times)

22. Select Yes to **write changes to disks** and **continue**

The partition tables of the following devices are changed:
SCSI1 (0,0,0) (sda)

The following partitions are going to be formatted:
partition #1 of SCSI1 (0,0,0) (sda) as ext4
partition #5 of SCSI1 (0,0,0) (sda) as swap

Write the changes to disks?

☐ No

☒ Yes

23. Let the system finish installing, and when done, select No for network mirror

24. Select **Yes** to install **GRUB boot loader** and continue to choose the device as shown below (**/dev/sda**)

Install the GRUB boot loader on a hard disk

You need to make the newly installed system bootable, by installing the GRUB boot loader on a bootable device. The usual way to do this is to install GRUB on the master boot record of your first hard drive. If you prefer, you can install GRUB elsewhere on the drive, or to another drive, or even to a floppy.

Device for boot loader installation:

Enter device manually

25. When the installation is complete, click **Continue** for the final cleanup

26. Click the **I Finished Installing** button at the bottom of your VMWare window.
If you cannot see this button, ignore this step

27. The system will restart. Login using **root/password** as the credentials

Setting up metasploitable 2:

1. Use the link to download metasploitable
<https://information.rapid7.com/metasploitable-download.html>

Metasploitable 2

<https://information.rapid7.com/metasploitable-download.html>

2. Then create vm in vmware as stated earlier.... Final results will be something like this



Practicing some commands

Check ip addr for both of the vms

1. For metasploit use command **ip a**

```
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 10.10.10.10/24 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast
    link/ether 00:0c:29:86:9e:3f brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.10/24 scope global eth0
        inet6 fe80::c29:86:9e:3f%eth0 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:86:9e:49 brd ff:ff:ff:ff:ff:ff
msfadmin@metasploitable:~$
```

2. For kali run **ip a** in terminal

Screenshot, sysinfo

```
meterpreter > sysinfo
Computer      : WIN-9DTLAB3LKDM
OS           : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > screenshot
Screenshot saved to: /home/kali123/AWYrcyKG.jpeg
```